

---

# Sprawozdanie z Laboratorium: Bazy Danych

Konrad Machowski

Jun 18, 2026

# CONTENTS

|          |                                                        |          |
|----------|--------------------------------------------------------|----------|
| <b>1</b> | <b>Wprowadzenie</b>                                    | <b>1</b> |
| <b>2</b> | <b>Spis treści</b>                                     | <b>2</b> |
| 2.1      | Wstęp do sprawozdania oraz linki . . . . .             | 2        |
| 2.1.1    | Wstęp do sprawozdania . . . . .                        | 2        |
| 2.1.2    | Wykaz repozytoriów (Linki) . . . . .                   | 2        |
| 2.2      | Badania literaturowe . . . . .                         | 3        |
| 2.2.1    | Sprzęt dla bazy danych . . . . .                       | 3        |
| 2.2.2    | Konfiguracja bazy danych PostgreSQL . . . . .          | 3        |
| 2.2.3    | Kontrola i konserwacja . . . . .                       | 10       |
| 2.2.4    | Monitorowanie i diagnostyka . . . . .                  | 12       |
| 2.2.5    | Wydajność, skalowanie i replikacja danych . . . . .    | 14       |
| 2.2.6    | Partycjonowanie danych . . . . .                       | 16       |
| 2.2.7    | Bezpieczeństwo Baz Danych . . . . .                    | 16       |
| 2.2.8    | Kopie zapasowe . . . . .                               | 23       |
| 2.3      | Zadanie 3 . . . . .                                    | 23       |
| 2.4      | Implementacja bazy danych i import danych . . . . .    | 23       |
| 2.4.1    | Definicja i inicjalizacja struktur danych . . . . .    | 24       |
| 2.4.2    | Zasilenie bazy danymi demonstracyjnymi . . . . .       | 25       |
| 2.4.3    | Koncepcja mechanizmów masowego importu (ETL) . . . . . | 25       |
| 2.5      | Zadanie 5 . . . . .                                    | 26       |

## WPROWADZENIE

Niniejsza dokumentacja stanowi kompletne sprawozdanie z laboratorium przedmiotu Bazy Danych. Projekt obejmuje całościową analizę procesów związanych z administracją i projektowaniem relacyjnych baz danych.

Dokumentacja została podzielona na pięć głównych sekcji:

- **Rozdział 1:** Wstęp do sprawozdania oraz wykaz repozytoriów z plikami projektowymi i submodułami.
- **Rozdział 2:** Przegląd źródeł akademickich i naukowo-technicznych dotyczących baz danych, ich architektury, optymalizacji i bezpieczeństwa.
- **Rozdział 3:** Praktyczne modelowanie systemu zarządzania bibliotecznym katalogiem wypożyczeń (analiza wymagań, model konceptualny E-R, model logiczny).
- **Rozdział 4:** Realizacja fizycznego schematu bazy danych poprzez skrypty DDL, mechanizmy importu danych oraz automatyzacja zasilania bazy w środowiskach PostgreSQL i SQLite.
- **Rozdział 5:** Zaawansowane funkcje SQL w Pythonie, selekcje, agregacje, złączenia, operatory zbiorowe i podzapytania.

## **SPIS TREŚCI**

## **2.1 Wstęp do sprawozdania oraz linki**

### **Autorzy**

1. Olaf Chomicki
2. Konrad Machowski
3. Wiktor Wydrzyński

### **2.1.1 Wstęp do sprawozdania**

Niniejsze sprawozdanie dokumentuje przebieg prac laboratoryjnych z przedmiotu Bazy Danych. Celem projektu jest praktyczne zastosowanie wiedzy z zakresu projektowania, wdrażania oraz obsługi systemów relacyjnych baz danych.

Praca obejmuje pełen cykl życia bazy: od analizy teoretycznej, poprzez stworzenie modelu pojęciowego i logicznego, aż po fizyczną implementację w środowiskach PostgreSQL i SQLite, a także realizację procesów wsadowego zasilania danymi.

### **2.1.2 Wykaz repozytoriów (Linki)**

Projekt został podzielony na odpowiednie repozytoria w systemie kontroli wersji Git, zapewniając porządek między dokumentacją a fizycznymi plikami środowiska bazodanowego.

#### **1. Główne repozytorium sprawozdania (Dokumentacja Sphinx)**

Tutaj znajduje się struktura całej dokumentacji tekstowej, konfiguracja kompilatora Sphinx oraz historia zmian.

- **Link:** <https://github.com/KMachok/Test.git>

#### **2. Repozytorium z plikami projektowymi**

W tym repozytorium umieszczono kody źródłowe, skrypty DDL dla silników PostgreSQL i SQLite, wygenerowany plik bazy oraz pliki CSV wykorzystywane do zasilania bazy danych.

- **Link:** <https://github.com/KMachok/Test.git>

#### **3. Repozytoria reszty grupy**

Poniżej znajdują się odnośniki do repozytoriów reszty grupy, które zostały zintegrowane z niniejszym sprawozdaniem w postaci submodułów w Rozdziale 2:

- **Grupa 1 (rozdział\_1):** <https://github.com/karaskamil/Sprzet-dla-bazy-danych.git>
- **Grupa 2 (rozdział\_2):** [https://github.com/Youarecheck/Bazy\\_Danych\\_Tematyczne\\_Repo\\_MK.git](https://github.com/Youarecheck/Bazy_Danych_Tematyczne_Repo_MK.git)
- **Grupa 3 (rozdział\_3):** <https://github.com/pawlos1337/Bazy-danych-temat.git>
- **Grupa 4 (rozdział\_4):** [https://github.com/OskarProgrammer/monitorowanie\\_i\\_diagnostyka.git](https://github.com/OskarProgrammer/monitorowanie_i_diagnostyka.git)
- **Grupa 5 (rozdział\_5):** <https://github.com/KMachok/Tematyczne.git>
- **Grupa 6 (rozdział\_6):** <https://github.com/domino0472/Partycjonowani-Danych>
- **Grupa 7 (rozdział\_7):** <https://github.com/oski486/BazyDanych-Subject.git>
- **Grupa 8 (rozdział\_8):** <https://github.com/Koko9077/Kopie-zapasowe-i-odzyskiwanie-danych.git>

## 2.2 Badania literaturowe

### 2.2.1 Sprzęt dla bazy danych

### 2.2.2 Konfiguracja bazy danych PostgreSQL

#### Wstęp

Rozdział opisuje konfigurację połączenia z bazą danych **PostgreSQL** – dojrzałym, open-source’owym systemem zarządzania relacyjnymi bazami danych (RDBMS), który wyróżnia się pełną zgodnością ze standardem SQL oraz silnym naciskiem na rozszerzalność i niezawodność.

#### Wymagania:

- dostęp do instancji PostgreSQL,
- zmienne środowiskowe,
- narzędzia projektowe (np. `psql`, `pg_isready`).

#### Podstawowe parametry

Każde połączenie z PostgreSQL wymaga:

- hosta i portu (domyślnie `localhost` i `5432`),
- nazwy bazy danych,
- użytkownika i hasła.

Dane wrażliwe (np. hasła) przechowuj w **zmiennych środowiskowych** – to oddziela konfigurację od kodu. Pamiętaj: zmienne środowiskowe nie są mechanizmem bezpieczeństwa; w produkcji uzupełnij je o dedykowane zarządzanie sekretami (np. HashiCorp Vault, AWS Secrets Manager).

#### Lokalizacja i struktura katalogów PostgreSQL

Pliki konfiguracyjne PostgreSQL znajdują się w katalogu danych (PGDATA).

#### Główne pliki konfiguracyjne:

- `postgresql.conf` – podstawowa konfiguracja serwera (port, pamięć, logi)
- `pg_hba.conf` – kontrola dostępu (kto i skąd może się łączyć)
- `pg_ident.conf` – mapowanie użytkowników systemowych na role PostgreSQL

#### Domyślne lokalizacje:

Table 1: Domyślne lokalizacje

| System                      | Katalog danych                                                                 |
|-----------------------------|--------------------------------------------------------------------------------|
| Linux (RPM/DEB)             | <code>/var/lib/pgsql/data/</code> lub <code>/var/lib/postgresql/*/main/</code> |
| Linux (kompilacja źródłowa) | <code>/usr/local/pgsql/data/</code>                                            |
| Windows                     | <code>C:\Program Files\PostgreSQL\&lt;version&gt;\data\</code>                 |
| Docker                      | <code>/var/lib/postgresql/data/</code> (w kontenerze)                          |

#### Zmiana katalogu danych:

```
# Inicjalizacja nowego katalogu
initdb -D /ścieżka/do/katalogu

# Uruchomienie z niestandardowym PGDATA
pg_ctl -D /ścieżka/do/katalogu start
```

#### Struktura katalogu danych:

```
$PGDATA/
├── postgresql.conf  # główny plik konfiguracyjny
├── pg_hba.conf      # polityka dostępu
└── pg_ident.conf    # mapowanie tożsamości
```

(continues on next page)

(continued from previous page)

```
└─ base/          # rzeczywiste bazy danych
└─ global/        # tabele systemowe
└─ log/           # logi serwera
└─ pg_wal/        # Write-Ahead Log (WAL)
```

### Sprawdzenie aktualnej lokalizacji:

```
SHOW data_directory;
SHOW config_file;
SHOW hba_file;
```

## Środowiska i profile

Przełączanie środowisk PostgreSQL (dev/test/prod) realizuj przez:

- zmienne środowiskowe (np. PGHOST, PGPORT, PGDATABASE, PGUSER, PGPASSWORD),
- profile konfiguracyjne,
- osobne pliki .env dla każdego środowiska.

## Automatyzacja

Zalecenia dla PostgreSQL:

- walidacja konfiguracji przy starcie za pomocą pg\_isready,
- skrypty sprawdzające kompletność zmiennych środowiskowych,
- integracja z CI/CD (np. GitHub Actions, GitLab CI).

Dokumentację generuj automatycznie (Sphinx).

## Przykłady

### PostgreSQL – zmienne środowiskowe (.env)

```
PGHOST=localhost
PGPORT=5432
PGDATABASE=aplikacja
PGUSER=app_user
PGPASSWORD=${DB_PASSWORD}
```

### PostgreSQL – URL połączenia

```
DATABASE_URL=postgresql://${PGUSER}:${PGPASSWORD}@${PGHOST}:${PGPORT}/${PGDATABASE}
```

### PostgreSQL – sprawdzenie połączenia

```
pg_isready -h ${PGHOST} -p ${PGPORT} -U ${PGUSER} -d ${PGDATABASE}
```

## Najlepsze praktyki

1. Nie przechowuj sekretów w repozytorium.
2. Stosuj .env.example zamiast rzeczywistych danych.
3. Używaj standardowych zmiennych środowiskowych PostgreSQL (PG\*).
4. Waliduj konfigurację przed uruchomieniem (pg\_isready).
5. W środowiskach produkcyjnych używaj połączeń SSL/TLS (sslmode=require).

## Podsumowanie

Poprawna konfiguracja połączenia z PostgreSQL zwiększa bezpieczeństwo i przenośność aplikacji między środowiskami. Standardowe zmienne środowiskowe oraz narzędzia takie jak `pg_isready` ułatwiają automatyzację i walidację.

## Szczegółowe omówienie plików konfiguracyjnych

Po omówieniu podstawowych wymagań środowiskowych można przejść do szczegółowej konfiguracji PostgreSQL. W kolejnych sekcjach przedstawiono najważniejsze parametry konfiguracyjne dostępne w plikach:

- `postgresql.conf` – konfiguracja działania serwera,
- `pg_hba.conf` – kontrola dostępu do bazy danych,
- `pg_ident.conf` – mapowanie użytkowników systemowych na role PostgreSQL.

### postgresql.conf

Plik `postgresql.conf` jest głównym plikiem konfiguracyjnym klastra PostgreSQL. Zawiera ustawienia wpływające na działanie serwera, wydajność, bezpieczeństwo, logowanie oraz replikację.

Lokalizację aktywnego pliku można sprawdzić poleceniem:

```
SHOW config_file;
```

## Najważniejsze parametry

### Połączenia sieciowe

#### listen\_addresses

Określa adresy IP, na których PostgreSQL nasłuchuje połączeń.

Najczęstsze wartości:

- `localhost` – tylko połączenia lokalne,
- `*` – wszystkie interfejsy sieciowe,
- lista adresów, np. `'192.168.1.10,localhost'`.

#### port

Port TCP używany przez PostgreSQL.

Domyślna wartość:

```
port = 5432
```

#### max\_connections

Maksymalna liczba jednoczesnych połączeń z bazą danych.

Zbyt wysoka wartość może zwiększać zużycie pamięci.

## Pamięć i wydajność

#### shared\_buffers

Ilość pamięci RAM używanej przez PostgreSQL do buforowania danych.

Typowe wartości:

- 128MB – środowiska testowe,
- 25% pamięci RAM – środowiska produkcyjne.

#### work\_mem

Ilość pamięci wykorzystywanej przez operacje sortowania i zapytania.

Parametr jest przydzielany dla pojedynczej operacji.

#### maintenance\_work\_mem

Pamięć używana podczas operacji administracyjnych, np.:

- `VACUUM`,
- `CREATE INDEX`,
- `ALTER TABLE`.

**effective\_cache\_size**

Szacowany rozmiar pamięci podręcznej dostępnej dla PostgreSQL.

Parametr pomaga optymalizatorowi zapytań wybierać odpowiednie plany wykonania.

**Logowanie****logging\_collector**

Włącza zapisywanie logów do plików.

Dostępne wartości:

- on,
- off.

**log\_directory**

Katalog przechowywania logów.

**log\_filename**

Wzorzec nazw plików logów.

Przykład:

```
log_filename = 'postgresql-%Y-%m-%d.log'
```

**log\_min\_duration\_statement**

Określa minimalny czas wykonania zapytania (w ms), po którym zostanie ono zapisane w logach.

Przykład:

```
log_min_duration_statement = 1000
```

Wartość 1000 oznacza logowanie zapytań trwających dłużej niż 1 sekundę.

**Bezpieczeństwo****password\_encryption**

Algorytm szyfrowania haseł użytkowników.

Zalecana wartość:

```
password_encryption = scram-sha-256
```

**ssl**

Włącza obsługę połączeń SSL/TLS.

Dostępne wartości:

- on,
- off.

**ssl\_cert\_file / ssl\_key\_file**

Ścieżki do certyfikatu i klucza prywatnego SSL.

**Replikacja i WAL****wal\_level**

Określa poziom szczegółowości Write-Ahead Log (WAL).

Dostępne wartości:

- minimal,
- replica,
- logical.

**max\_wal\_size**

Maksymalny rozmiar plików WAL przed wykonaniem checkpointu.

**archive\_mode**

Włącza archiwizację WAL.

**archive\_command**

Polecenie wykonywane podczas archiwizacji plików WAL.

## Przykładowa konfiguracja

```
listen_addresses = '*'
port = 5432
max_connections = 200

shared_buffers = 1GB
work_mem = 16MB
maintenance_work_mem = 256MB

logging_collector = on
log_directory = 'log'

ssl = on
password_encryption = scram-sha-256

wal_level = replica
max_wal_size = 2GB
```

## Weryfikacja konfiguracji

Po zmianie parametrów konfigurację można przeładować bez restartu serwera:

```
SELECT pg_reload_conf();
```

Niektóre parametry wymagają pełnego restartu PostgreSQL.  
Aktualne wartości parametrów można sprawdzić poleceniem:

```
SHOW shared_buffers;
SHOW wal_level;
SHOW max_connections;
```

## pg\_hba.conf

Plik `pg_hba.conf` (Host-Based Authentication) odpowiada za kontrolę dostępu do serwera PostgreSQL.  
Definiuje:

- kto może połączyć się z bazą danych,
- z jakiego adresu IP,
- do jakiej bazy danych,
- przy użyciu jakiej metody uwierzytelniania.

Lokalizację aktywnego pliku można sprawdzić poleceniem:

```
SHOW hba_file;
```

## Składnia wpisu

Każdy wpis w `pg_hba.conf` ma następującą strukturę:

| TYPE | DATABASE | USER | ADDRESS | METHOD |
|------|----------|------|---------|--------|
|------|----------|------|---------|--------|

Znaczenie pól:

### TYPE

Typ połączenia.

Dostępne wartości:

- `local` – połączenia lokalne (Unix socket),

- `host` – połączenia TCP/IP,
- `hostssl` – połączenia TCP/IP z SSL,
- `hostnoss1` – połączenia TCP/IP bez SSL.

**DATABASE**

Nazwa bazy danych, do której użytkownik może się połączyć.

Możliwe wartości:

- konkretna nazwa bazy,
- `all` – wszystkie bazy,
- `sameuser` – baza o nazwie zgodnej z użytkownikiem.

**USER**

Użytkownik lub rola PostgreSQL.

**ADDRESS**

Adres IP lub zakres sieci w notacji CIDR.

Przykłady:

- `127.0.0.1/32`,
- `192.168.1.0/24`,
- `0.0.0.0/0` – wszystkie adresy.

**METHOD**

Metoda uwierzytelniania użytkownika.

**Najczęściej używane metody uwierzytelniania****trust**

Zezwala na połączenie bez uwierzytelniania.

Zalecane wyłącznie w środowiskach testowych.

**reject**

Odrzuca połączenie.

**md5**

Uwierzytelnianie przy użyciu hasła MD5.

Metoda starsza i mniej bezpieczna niż SCRAM.

**scram-sha-256**

Nowoczesna metoda uwierzytelniania oparta na SCRAM.

Zalecana dla nowych instalacji PostgreSQL.

**peer**

Uwierzytelnianie na podstawie użytkownika systemowego.

Najczęściej używane dla lokalnych połączeń Linux/Unix.

**ident**

Mapowanie użytkownika systemowego przy użyciu `pg_ident.conf`.

**Przykładowa konfiguracja**

```
# Połączenia lokalne
local  all                                postgres                                peer

# Połączenia localhost IPv4
host   all                                all                                127.0.0.1/32                        scram-sha-256

# Połączenia localhost IPv6
host   all                                all                                ::1/128                            scram-sha-256

# Sieć lokalna
host   aplikacja                          app_user                          192.168.1.0/24                      scram-sha-256
```

## Najlepsze praktyki

1. Używaj `scram-sha-256` zamiast `md5`.
2. Ograniczaj dostęp do konkretnych adresów IP.
3. Nie używaj `trust` w środowiskach produkcyjnych.
4. Stosuj `hostssl` dla połączeń zdalnych.
5. Po zmianie konfiguracji wykonuj reload konfiguracji:

```
SELECT pg_reload_conf();
```

## pg\_ident.conf

Plik `pg_ident.conf` umożliwia mapowanie użytkowników systemowych na role PostgreSQL.

Najczęściej używany jest razem z metodami uwierzytelniania:

- `peer`,
- `ident`.

Lokalizację aktywnego pliku można sprawdzić poleceniem:

```
SHOW ident_file;
```

## Zastosowanie

Mechanizm mapowania pozwala określić, który użytkownik systemowy może zostać powiązany z konkretną rolą PostgreSQL.

Jest to szczególnie przydatne:

- w środowiskach Linux/Unix,
- przy automatyzacji administracyjnej,
- dla lokalnych połączeń bez użycia haseł.

## Składnia wpisu

| MAPNAME | SYSTEM-USERNAME | PG-USERNAME |
|---------|-----------------|-------------|
|---------|-----------------|-------------|

Znaczenie pól:

### MAPNAME

Nazwa mapowania wykorzystywana w `pg_hba.conf`.

### SYSTEM-USERNAME

Użytkownik systemu operacyjnego.

### PG-USERNAME

Rola PostgreSQL, na którą użytkownik ma zostać zmapowany.

## Przykładowa konfiguracja

| # MAPNAME | SYSTEM-USERNAME | PG-USERNAME |
|-----------|-----------------|-------------|
| admin_map | postgres        | postgres    |
| admin_map | deploy          | db_admin    |
| app_map   | appuser         | aplikacja   |

Przykład użycia w `pg_hba.conf`:

```
local all all peer map=admin_map
```

W powyższym przykładzie użytkownicy systemowi zdefiniowani w `admin_map` mogą logować się jako odpowiadające im role PostgreSQL.

## Najlepsze praktyki

1. Ograniczaj mapowania wyłącznie do wymaganych użytkowników.
2. Nie mapuj użytkowników systemowych na role superuser bez uzasadnienia.
3. Stosuj osobne role administracyjne i aplikacyjne.
4. Dokumentuj wszystkie mapowania użytkowników.
5. Regularnie przeglądaj konfigurację dostępu.

### Opracowanie

**Autor:** Michał Kraus **Przedmiot:** Bazy danych **Data:** maj 2026

## 2.2.3 Kontrola i konserwacja

### Autorzy

1. Paweł Łoćwin
2. Paweł Łosowski

## Wprowadzenie

Współczesne systemy relacyjnych baz danych to wysoce skomplikowane środowiska, które wymagają ciągłego i proaktywnego nadzoru, aby zagwarantować wysoką dostępność, niezawodność oraz wydajność. Administracja takimi systemami stanowi złożone zagadnienie wymagające zarówno wiedzy teoretycznej, jak i praktycznego doświadczenia w zarządzaniu infrastrukturą informatyczną.

## Zarządzanie przestrzenią i mechanizm współbieżności

PostgreSQL opiera swoje działanie na zaawansowanej architekturze określanej jako Multi-Version Concurrency Control (MVCC). Technologia ta pozwala na równoległy odczyt i zapis danych bez wzajemnego blokowania się transakcji, co stanowi fundamentalną zaletę w środowiskach wieloużytkownikowych o wysokim natężeniu operacji. Aby zapobiec zjawisku drastycznego puchnięcia tabel oraz degradacji wydajności operacji wejścia i wyjścia, konieczna jest regularna konserwacja na poziomie nośnika danych:

- **VACUUM:** Podstawowy proces konserwacyjny odzyskujący miejsce po martwych krotkach. Oznacza on wolne obszary jako dostępne do ponownego zapisu przez nowe instrukcje, zapobiegając niekontrolowanemu wzrostowi rozmiarów tabel na dysku.
- **VACUUM FULL:** Znacznie bardziej inwazyjna wersja operacji, która fizycznie przebudowuje strukturę całej tabeli i trwale zwraca wolne miejsce do systemu operacyjnego. Operacja ta wymaga jednak zablokowania całej tabeli i powinna być wykonywana w godzinach niskiego obciążenia.
- **AUTOVACUUM:** W nowoczesnych środowiskach produkcyjnych utrzymanie czystości dyskowej powierza się wbudowanemu procesowi pracującemu w tle. Monitoruje on na bieżąco statystyki zmian i automatycznie wyzwała operacje czyszczenia, eliminując potrzebę ręcznej interwencji administratora.

Zaniebdanie procesu czyszczenia w systemach o wysokiej rotacji danych może doprowadzić nie tylko do spadku wydajności, ale w skrajnych przypadkach do wyczerpania identyfikatorów transakcji, co prowadzi do całkowitego zamrożenia bazy.

```
-- Przykładowe wymuszenie manualnej konserwacji z analizą statystyk dla tabeli
VACUUM (VERBOSE, ANALYZE) Wypozyczenia;
```

## Optymalizacja i statystyki planisty zapytań

Kolejnym filarem utrzymania sprawności systemu jest kontrola nad optymalizatorem, zwanym planistą zapytań. Silnik bazy danych przed wykonaniem jakiegokolwiek skomplikowanej kwerendy analizuje dostępne drogi realizacji i wybiera najefektywniejszą z punktu widzenia kosztów obliczeniowych.

Aby planista mógł podejmować optymalne decyzje, musi opierać się na wysoce dokładnych i aktualnych statystykach dotyczących rozkładu danych. Obejmują one między innymi histogramy wartości w kolumnach, liczby odrębnych wartości (distinct count), oraz rozmiary tabel i indeksów.

- Instrukcja **ANALYZE** służy do natychmiastowego odświeżenia tych metadanych. Baza pobiera losową próbkę wierszy i na jej podstawie aktualizuje wewnętrzne tabele systemowe, co pozwala uniknąć błędnych oszacowań planu wykonania.
- Bieżące profilowanie wydajności realizowane jest natomiast przy pomocy instrukcji **EXPLAIN ANALYZE**. Narzędzie to uruchamia zapytanie, po czym zwraca nie tylko wynik, ale również szczegółowy opis planu wykonania wraz z rzeczywistymi czasami i liczbami wierszy na każdym kroku.

```
-- Kontrola planu wykonania zapytania z rzeczywistym pomiarem czasu
EXPLAIN ANALYZE
SELECT c.Imie, c.Nazwisko, k.Tytul
FROM Czytelnicy c
JOIN Wypozyczenia w ON c.ID_Czytelnika = w.ID_Czytelnika
JOIN Ksiazki k ON w.ID_Ksiazki = k.ID_Ksiazki
WHERE w.Data_Zwrotu IS NULL;
```

## Bezpieczeństwo i rygorystyczna kontrola dostępu

Bezpieczeństwo danych stanowi absolutny priorytet każdej administracji systemami informatycznymi. Nowoczesne podejście do ochrony baz danych całkowicie odchodzi od wykorzystywania globalnych kont administratora na rzecz zaawansowanego systemu uprawnień opartego na rolach (RBAC – Role-Based Access Control).

System zabezpieczeń środowiska PostgreSQL pozwala na niezwykle elastyczną gradację uprawnień. Definiuje się dedykowane role systemowe przypisane do konkretnych mikrousług lub modułów aplikacji, z precyzyjnie określonymi prawami dostępu do pojedynczych schematów, tabel, a nawet kolumn.

Kluczowym konceptem jest wdrożenie zasady najmniejszych uprawnień (Principle of Least Privilege). Rola wykorzystywana przez aplikację powinna dysponować prawami pozwalającymi wyłącznie na modyfikację danych niezbędnych do jej funkcjonowania, bez dostępu do danych wrażliwych czy możliwości zmiany struktury bazy.

```
-- Przykład implementacji bezpiecznej polityki kontroli dostępu
CREATE ROLE app_user WITH LOGIN PASSWORD 'TrudneHaslo123';
GRANT CONNECT ON DATABASE biblioteka_db TO app_user;
GRANT USAGE ON SCHEMA public TO app_user;
GRANT SELECT, INSERT ON Wypozyczenia TO app_user;
```

## Strategie zabezpieczania przed utratą danych

Nawet najlepiej zoptymalizowany i zabezpieczony system informatyczny jest narażony na błędy ludzkie lub awarie infrastruktury sprzętowej. Dlatego odpowiednia polityka wykonywania kopii zapasowych stanowi ostateczną linię obrony i jest absolutnie niezbędna dla każdej produkcyjnej instancji bazy danych.

Kopie logiczne polegają na ekstrakcji danych z bazy do postaci czystego skryptu języka SQL lub dedykowanego formatu archiwalnego. Narzędzia realizujące to zadanie gwarantują przenośność danych między platformami i wersjami silnika, jednak proces przywracania jest czasochłonny i może nie przywrócić wszystkich zmian z ostatnich minut przed awarią.

Dlatego w krytycznych środowiskach produkcyjnych stosuje się kopie fizyczne połączone z archiwizacją dzienników wyprzedzających. Dzienniki te rejestrują absolutnie każdą zmianę bajtu na poziomie magazynu, co umożliwia odtworzenie bazy do dowolnego punktu w przeszłości z dokładnością do sekundy.

## Podsumowanie

Prawidłowa kontrola i konserwacja środowiska bazodanowego to wielowymiarowy proces, który nie ma punktu końcowego, lecz trwa przez cały cykl życia oprogramowania. Złożoność nowoczesnych systemów relacyjnych wymaga holistycznego podejścia łączącego automatyzację, monitoring i ciągłe doskonalenie.

Samo zaprojektowanie zgodnego ze sztuką schematu relacyjnego jest zaledwie początkiem pracy. Stabilność aplikacji zależy w równej mierze od rygorystycznego zarządzania fizyczną strukturą danych, optymalizacji wykonywanych operacji oraz wdrażania wielowarstwowych strategii bezpieczeństwa i ochrony przed awarią.

Holistyczne spojrzenie na administrację PostgreSQL, obejmujące zarówno automatyzację procesów porządkujących pamięć, jak i ciągle monitorowanie planów wykonania zapytań, pozwala na budowanie systemów, które są nie tylko funkcjonalne, ale także odporne i niezawodne w najbardziej wymagających warunkach produkcyjnych.

## 2.2.4 Monitorowanie i diagnostyka

### Autorzy

1. Oskar Wrona
2. Kamil Lewandowski
3. Adam Tarkowski

### Wstęp

Monitorowanie i diagnostyka baz danych obejmują zestaw działań, które pozwalają administratorowi lub zespołowi utrzymania sprawdzić, czy system działa poprawnie, bezpiecznie i wydajnie. W praktyce nie chodzi jedynie o obserwowanie pojedynczych parametrów serwera, ale o łączenie informacji pochodzących z wielu warstw: samej bazy danych, systemu operacyjnego, aplikacji oraz narzędzi zewnętrznych. Dzięki temu można szybciej wykrywać przeciążenia, błędy konfiguracji, problemy z zapytaniami SQL, nieprawidłowe uprawnienia oraz awarie sprzętowe lub sieciowe.

W systemach bazodanowych szczególnie ważne jest to, że wiele problemów nie jest od razu widocznych dla użytkownika końcowego. Przykładowo zapytania mogą stopniowo wykonywać się coraz wolniej, liczba aktywnych sesji może rosnąć, a logi mogą zawierać powtarzające się ostrzeżenia. Bez monitorowania takie sygnały są łatwe do przeoczenia. Diagnostyka pozwala natomiast przejść od samego wykrycia problemu do ustalenia jego przyczyny, np. przez analizę sesji, blokad, planów zapytań, dzienników błędów lub zużycia zasobów systemowych.

### Sesje i użytkownicy

Jednym z podstawowych obszarów monitorowania bazy danych jest obserwowanie aktywnych sesji i użytkowników. Sesja oznacza połączenie użytkownika lub aplikacji z serwerem bazy danych. W ramach sesji wykonywane są zapytania, transakcje oraz operacje administracyjne. Analiza sesji pozwala sprawdzić między innymi, kto jest aktualnie połączony z bazą, z jakiego hosta pochodzi połączenie, jakie zapytanie jest wykonywane oraz czy sesja jest aktywna, beczynna albo zablokowana.

W wielu systemach zarządzania bazami danych dostępne są specjalne widoki lub narzędzia administracyjne służące do obserwowania bieżącej aktywności. Na przykład PostgreSQL udostępnia mechanizmy monitorowania aktywności bazy danych oraz widoki statystyczne, takie jak `pg_stat_activity`, które pozwalają sprawdzać informacje o procesach serwera i wykonywanych zapytaniach<sup>1</sup>. W MySQL podobną rolę może pełnić Performance Schema, które gromadzi dane diagnostyczne o pracy serwera i może być wykorzystywane do analizy wydajności<sup>2</sup>. Monitorowanie sesji jest istotne zarówno z punktu widzenia wydajności, jak i bezpieczeństwa. Zbyt duża liczba jednoczesnych połączeń może prowadzić do przeciążenia serwera, a długo działające transakcje mogą blokować inne operacje. Z kolei nietypowe połączenia, np. z nieznanych adresów lub wykonywane poza normalnymi godzinami pracy, mogą wskazywać na błąd konfiguracji albo próbę nieautoryzowanego dostępu.

### Śledzenie dostępu użytkowników do tabel

Kolejnym ważnym elementem jest kontrola tego, którzy użytkownicy uzyskują dostęp do określonych tabel i jakie operacje wykonują. W bazach danych przechowywane są często dane wrażliwe, dlatego sama informacja o tym, że użytkownik posiada konto w systemie, nie jest wystarczająca. Należy również wiedzieć, czy jego działania są zgodne z nadanymi uprawnieniami oraz z zasadami bezpieczeństwa obowiązującymi w organizacji.

Śledzenie dostępu może obejmować operacje odczytu danych, modyfikacji rekordów, usuwania danych, tworzenia nowych obiektów oraz zmian w uprawnieniach. W praktyce realizuje się to za pomocą mechanizmów audytu, dzienników zapytań, wyzwalaczy, narzędzi klasy Database Activity Monitoring lub funkcji wbudowanych w

<sup>1</sup> PostgreSQL Documentation, *Monitoring Database Activity* oraz *The Cumulative Statistics System*, <https://www.postgresql.org/docs/current/monitoring.html>

<sup>2</sup> MySQL Documentation, *Using the Performance Schema to Diagnose Problems*, <https://dev.mysql.com/doc/refman/8.2/en/performance-schema-examples.html>

konkretny system bazodanowy. Przykładowo Oracle Database udostępnia mechanizmy audytu, a nowsze wersje zalecają korzystanie z unified auditing zamiast starszego audytu tradycyjnego<sup>3</sup>.

Takie śledzenie jest potrzebne nie tylko przy wykrywaniu incydentów bezpieczeństwa. Pomaga również w spełnianiu wymagań formalnych, analizie błędów użytkowników oraz odtwarzaniu przebiegu zdarzeń po awarii. Przykładowo, jeśli w tabeli pojawiły się nieprawidłowe dane, historia dostępu może pomóc ustalić, kiedy doszło do zmiany i która aplikacja lub który użytkownik ją wykonał.

## Błędy dziennika, logi i raporty

Dzienniki zdarzeń, czyli logi, są jednym z najważniejszych źródeł informacji diagnostycznych. Serwer bazy danych może zapisywać w nich komunikaty o błędach, ostrzeżeniach, nieudanych logowaniach, problemach z zapytaniem, restartach, zmianach konfiguracji lub przekroczeniu określonych progów wydajnościowych. Analiza logów pozwala wykrywać problemy, które nie zawsze są widoczne w aplikacji klienckiej.

W zależności od systemu bazodanowego logi mogą mieć różną postać. PostgreSQL obsługuje różne metody logowania komunikatów serwera, między innymi `stderr`, `csvlog`, `jsonlog` oraz `syslog`; w systemie Windows możliwe jest także użycie dziennika zdarzeń<sup>4</sup>. MySQL udostępnia między innymi `general query log`, który może rejestrować połączenia i zapytania otrzymywane przez serwer, oraz `slow query log`, używany do identyfikowania zapytań wykonujących się zbyt długo<sup>5</sup>.

Raporty diagnostyczne są rozwinięciem surowych logów. Zamiast ręcznie analizować tysiące wpisów, administrator może korzystać z raportów podsumowujących liczbę błędów, najwolniejsze zapytania, częstotliwość nieudanych logowań lub zmiany obciążenia w czasie. Raporty są szczególnie przydatne w pracy zespołowej, ponieważ pozwalają dokumentować problemy i porównywać stan systemu przed oraz po wprowadzeniu zmian optymalizacyjnych.

## Monitorowanie na poziomie systemu operacyjnego

Baza danych działa na konkretnym systemie operacyjnym i korzysta z jego zasobów. Dlatego diagnostyka nie może ograniczać się wyłącznie do samego silnika bazy danych. Wydajność zapytań może zależeć od procesora, pamięci RAM, operacji wejścia/wyjścia na dysku, sieci, liczby procesów oraz ogólnego obciążenia systemu.

W systemach Linux często wykorzystuje się narzędzia takie jak `iostat`, `htop` oraz `vmstat`. Narzędzie `iostat` pozwala obserwować wykorzystanie procesora i urządzeń wejścia/wyjścia, co jest szczególnie ważne przy bazach danych intensywnie korzystających z dysku. `htop` umożliwia wygodne śledzenie procesów i zużycia zasobów w czasie rzeczywistym. `vmstat` pokazuje między innymi informacje o pamięci, procesach, wymianie danych z dyskiem oraz obciążeniu procesora.

W systemach Microsoft Windows podobną rolę pełnią Menedżer zadań oraz Monitor wydajności. Pozwalają one obserwować zużycie procesora, pamięci, dysków, sieci oraz usług działających w tle. W środowiskach produkcyjnych takie dane są często zbierane automatycznie i zestawiane z metrykami pochodzącymi z bazy danych. Dzięki temu można odróżnić problem wynikający z nieoptymalnego zapytania SQL od problemu spowodowanego np. przeciążeniem dysku lub brakiem pamięci.

## Monitorowanie serwera

Ostatnim poziomem jest monitorowanie całego serwera lub infrastruktury, w której działa baza danych. Obejmuje ono dostępność usług, czas odpowiedzi, zużycie zasobów, stan dysków, wykorzystanie sieci, działanie kopii zapasowych oraz wysyłanie powiadomień w przypadku awarii. W tym celu stosuje się narzędzia takie jak Nagios, Grafana, Prometheus, Zabbix lub inne systemy monitoringu.

Nagios jest przykładem narzędzia używanego do monitorowania usług i hostów, sprawdzania ich stanu oraz informowania administratorów o problemach<sup>6</sup>. Grafana z kolei służy przede wszystkim do wizualizacji danych monitorujących w formie dashboardów. Panele Grafany mogą prezentować metryki w postaci wykresów, tabel i innych

<sup>3</sup> Oracle Documentation, *AUDIT\_TRAIL* oraz informacje o unified auditing, [https://docs.oracle.com/en/database/oracle/oracle-database/21/refrn/AUDIT\\_TRAIL.html](https://docs.oracle.com/en/database/oracle/oracle-database/21/refrn/AUDIT_TRAIL.html)

<sup>4</sup> PostgreSQL Documentation, *Error Reporting and Logging*, <https://www.postgresql.org/docs/current/runtime-config-logging.html>

<sup>5</sup> MySQL Documentation, *The General Query Log* oraz *The Slow Query Log*, <https://dev.mysql.com/doc/en/query-log.html>

<sup>6</sup> Nagios Open Source Documentation, <https://www.nagios.org/documentation/>

wizualizacji, a moduł alertów pozwala reagować na określone zdarzenia lub przekroczenie progów<sup>7</sup>.

Monitorowanie serwera jest szczególnie ważne w środowiskach, w których baza danych stanowi element większego systemu. Awaria bazy może wynikać nie tylko z błędu samego silnika, ale również z problemu sieciowego, zapełnionego dysku, braku pamięci, błędnej konfiguracji systemu lub nieudanego wdrożenia aplikacji. Centralne monitorowanie pozwala zebrać te informacje w jednym miejscu i szybciej wskazać źródło problemu.

## Znaczenie monitorowania i diagnostyki w bazach danych

Monitorowanie i diagnostyka są ważne, ponieważ wpływają na trzy kluczowe obszary: dostępność, wydajność i bezpieczeństwo danych. Dostępność oznacza, że baza danych jest osiągalna dla użytkowników i aplikacji. Wydajność oznacza, że zapytania wykonują się w akceptowalnym czasie. Bezpieczeństwo oznacza natomiast, że dostęp do danych jest kontrolowany, a podejrzane działania mogą zostać wykryte i przeanalizowane.

W dobrze utrzymanym środowisku bazodanowym monitorowanie powinno działać stale, a nie dopiero wtedy, gdy pojawi się awaria. Regularne obserwowanie sesji, logów, dostępu do tabel, parametrów systemu operacyjnego i stanu serwera pozwala wykrywać problemy na wczesnym etapie. Diagnostyka pozwala natomiast ustalić przyczyny tych problemów i zaplanować odpowiednie działania, takie jak optymalizacja zapytań, zmiana konfiguracji, zwiększenie zasobów, poprawa uprawnień lub wdrożenie dodatkowych zabezpieczeń.

## Podsumowanie

Monitorowanie i diagnostyka baz danych tworzą wielowarstwowy proces kontroli działania systemu. Na poziomie bazy danych analizuje się sesje, użytkowników, zapytania, blokady, dostęp do tabel oraz logi. Na poziomie systemu operacyjnego obserwuje się zużycie procesora, pamięci, dysku i sieci. Na poziomie serwera wykorzystuje się narzędzia monitorujące, które zbierają metryki, tworzą wykresy oraz wysyłają alerty. Dopiero połączenie tych perspektyw daje pełny obraz stanu systemu i pozwala skutecznie reagować na błędy, spadki wydajności oraz potencjalne incydenty bezpieczeństwa.

## Źródła

### 2.2.5 Wydajność, skalowanie i replikacja danych

Autorzy:

1. Olaf Chomicki
2. Konrad Machowski
3. Wiktor Wydrzyński

## Wstęp

W erze gwałtownego wzrostu ilości generowanych informacji, stabilne działanie systemów bazodanowych stało się fundamentem nowoczesnych aplikacji. Wydajność, skalowanie oraz replikacja to trzy ściśle powiązane ze sobą filary, które decydują o tym, czy baza danych będzie w stanie obsłużyć rosnącą liczbę użytkowników oraz operacji w jednostce czasu. Zrozumienie różnic oraz synergii między tymi pojęciami jest kluczowe dla każdego architekta oprogramowania<sup>1</sup>.

Podczas gdy wydajność skupia się na optymalizacji istniejących zasobów w celu jak najszybszego przetwarzania pojedynczych żądań, skalowanie i replikacja odpowiadają na wyzwania związane z ograniczeniami sprzętowymi oraz koniecznością zapewnienia ciągłości działania systemu w przypadku awarii.

<sup>7</sup> Grafana Documentation, *Dashboards overview* oraz *Grafana Alerting*, <https://grafana.com/docs/grafana/latest/fundamentals/dashboards-overview/>

<sup>1</sup> "Projektowanie systemów rozproszonych" – Podstawy skalowalności baz danych.

## Wydajność baz danych

Wydajność (Performance) odnosi się do szybkości, z jaką system bazodanowy reaguje na zapytania i transakcje. Na poziomie pojedynczej instancji kluczowe znaczenie ma optymalizacja kodu SQL, poprawne projektowanie indeksów oraz unikanie kosztownych operacji, takich jak pełne skanowanie tabel (Full Table Scan). Optymalizator bazy danych stara się dobrać najlepszą ścieżkę wykonania zapytania, jednak jego skuteczność zależy od aktualności statystyk oraz struktury danych<sup>2</sup>.

Po stronie sprzętowej wąskimi gardłami najczęściej stają się operacje wejścia/wyjścia (I/O) dysków, dostępna pamięć RAM (służąca jako bufor dla często odczytywanych stron danych) oraz moc procesora. Wyczerpanie tych zasobów bezpośrednio przekłada się na wzrost opóźnień (latency) i spadek przepustowości (throughput).

## Skalowanie: Pionowe vs. Poziome

Gdy optymalizacja zapytań przestaje wystarczać, system musi zostać poddany skalowaniu. Skalowanie pionowe (Scaling Up) polega na zwiększaniu zasobów pojedynczej maszyny – dodaniu szybszych procesorów, większej ilości pamięci RAM lub wydajniejszych dysków SSD. Jest to najprostsze podejście, niepoprawiające jednak architektury aplikacji, ale ma swoje fizyczne i ekonomiczne granice (prawo malejących przychodów oraz limit techniczny serwera)<sup>3</sup>.

Skalowanie poziome (Scaling Out) polega na dodawaniu kolejnych maszyn do klastra. W kontekście baz danych jest to zadanie znacznie trudniejsze niż w przypadku bezstanowych aplikacji webowych, ponieważ wymaga mechanizmów dystrybucji danych. Jedną z głównych metod skalowania poziomego zapisu jest sharding, czyli fizyczny podział bazy na niezależne węzły.

## Replikacja danych i wysoka dostępność

Replikacja to proces kopiowania danych z jednego serwera bazy danych (węzła głównego/Primary) na jeden lub więcej serwerów pomocniczych (węzłów potomnych/Replica). Głównym celem replikacji jest zapewnienie wysokiej dostępności (High Availability) – w razie awarii serwera głównego, jedna z replik może przejąć jego funkcję, minimalizując czas przestoju systemu<sup>4</sup>.

Dodatkowo replikacja pozwala na skalowanie operacji odczytu (Read Scalability). Aplikacja może kierować zapytania modyfikujące dane (INSERT, UPDATE) do węzła Primary, natomiast ciężkie zapytania raportowe i odczyty rozpraszać na repliki. Replikacja może odbywać się synchronicznie (gwarantuje spójność danych, ale zwalnia zapisy) lub asynchronicznie (szybsza, ale niesie ryzyko utraty ostatnich transakcji w przypadku nagłej awarii).

## Wyzwania i kompromisy architektoniczne

Budowanie systemów wysoce skalowalnych i zreplikowanych wiąże się z koniecznością akceptacji kompromisów, co formalnie opisuje twierdzenie CAP (Consistency, Availability, Partition Tolerance). Mówi ono, że w rozproszonym systemie komputerowym można jednocześnie zapewnić tylko dwie z trzech wymienionych cech<sup>5</sup>.

W praktyce systemy bazodanowe często muszą wybierać pomiędzy silną spójnością danych (wszyscy użytkownicy widzą dokładnie to samo w tym samym momencie) a wysoką dostępnością i niskimi opóźnieniami, co doprowadziło do popularyzacji modeli spójności ostatecznej (Eventual Consistency) w bazach typu NoSQL.

## Podsumowanie

Wydajność, skalowanie i replikacja nie są niezależnymi wyspami – to naczynia połączone. Dobrze zoptymalizowana pod kątem wydajności baza danych odwleka w czasie moment, w którym konieczne stanie się kosztowne skalowanie. Z kolei właściwie wdrożona replikacja nie tylko zabezpiecza system przed utratą danych, ale stanowi naturalny krok w kierunku poziomego skalowania odczytów. Architektura systemu musi być stale dostosowywana do dynamicznie zmieniających się wymagań biznesowych oraz skali operacji.

<sup>2</sup> "Optymalizacja zapytań i indeksowanie w relacyjnych bazach danych".

<sup>3</sup> Analiza kosztów i barier technologicznych w skalowaniu pionowym.

<sup>4</sup> Mechanizmy replikacji synchronicznej i asynchronicznej w systemach High Availability.

<sup>5</sup> Twierdzenie CAP a praktyczne implementacje nowoczesnych magazynów danych.

## 2.2.6 Partycjonowanie danych

## 2.2.7 Bezpieczeństwo Baz Danych

Dział 7 przeglądu literaturowego poświęcony architekturze bezpieczeństwa, mechanizmom ochrony oraz analizie podatności w nowoczesnych systemach zarządzania bazami danych.

### 1. Model bezpieczeństwa CIA i ochrona infrastruktury

Rozważając bezpieczeństwo systemów bazodanowych, należy spojrzeć na problem warstwowo. Najniższą, a zarazem najbardziej fundamentalną warstwą jest ochrona samej infrastruktury sprzętowej i sieciowej, na której operuje silnik bazy danych (DBMS). Zanim przejdziemy do szczegółowych konfiguracji silnika, konieczne jest zdefiniowanie nadrzędnych celów bezpieczeństwa oraz zapewnienie izolacji środowiska uruchomieniowego.

#### Triada CIA w środowisku bazodanowym

Model CIA (ang. *Confidentiality, Integrity, Availability*) to klasyczny paradygmat bezpieczeństwa informacji. W kontekście relacyjnych i nierelacyjnych baz danych każdy z tych elementów realizowany jest przez specyficzne mechanizmy:

- **Poufność (Confidentiality):** Gwarantuje, że dane są dostępne wyłącznie dla autoryzowanych podmiotów. W bazach danych osiąga się to poprzez ścisłą kontrolę dostępu (np. RBAC), szyfrowanie danych w spoczynku (TDE - *Transparent Data Encryption*), maskowanie danych wrażliwych oraz szyfrowanie połączeń sieciowych (TLS).
- **Integralność (Integrity):** Zapewnia spójność i poprawność danych, chroniąc je przed nieautoryzowaną modyfikacją. Silniki bazodanowe realizują ten postulat natywnie poprzez właściwości ACID (szczególnie *Consistency*), więzy integralności (klucze obce, ograniczenia *CHECK*), a z punktu widzenia bezpieczeństwa – poprzez audytowanie DML (Data Manipulation Language) i mechanizmy wykrywania anomalii.
- **Dostępność (Availability):** Oznacza pewność, że system odpowie na żądanie w akceptowalnym czasie. Zagrożeniem dla dostępności są awarie sprzętowe oraz ataki DoS. Obroną na poziomie bazy danych są klastry wysokiej dostępności (HA), replikacja (np. *Master-Slave, Multi-Master*), partycjonowanie oraz odpowiednio zaprojektowane mechanizmy Disaster Recovery.

#### Izolacja sieciowa i architektura chmurowa (VPC)

Nawet najlepiej skonfigurowany system uprawnień bazodanowych traci na znaczeniu, jeśli instancja wystawiona jest bezpośrednio do publicznej sieci Internet. Standardem inżynieryjnym w nowoczesnych wdrożeniach (zarówno on-premise, jak i cloud) jest głęboka separacja sieciowa.

W środowiskach chmurowych (np. AWS, Azure, GCP) bazy danych umieszcza się w dedykowanych chmurach prywatnych (VPC - *Virtual Private Cloud*). Dobrą praktyką jest wdrożenie architektury wielowarstwowej:

1. **Warstwa publiczna (Public Subnet):** Zawiera load balancery i serwery webowe (np. Nginx), do których dostęp ma użytkownik końcowy.
2. **Warstwa aplikacji (Private Subnet):** Środowisko uruchomieniowe backendu (np. Node.js, Spring Boot).
3. **Warstwa danych (Database Subnet):** Najgłębiej ukryta podsieć prywatna bez routingu do Internetu (brak *Internet Gateway*). Dostęp do niej ma wyłącznie warstwa aplikacji poprzez ściśle określone reguły *Security Groups* lub *Network ACLs* (dopuszczające ruch tylko na konkretnym porcie, np. 5432 dla PostgreSQL, i tylko ze znanych adresów IP warstwy aplikacyjnej).

Takie podejście drastycznie zmniejsza powierzchnię ataku (ang. *attack surface*), eliminując ryzyko bezpośrednich ataków typu *brute-force* na porty bazy danych z zewnątrz.

#### Konteneryzacja a bezpieczeństwo bazy

Uruchamianie baz danych w kontenerach (np. Docker, Kubernetes) stało się powszechne, jednak niesie ze sobą specyficzne wektory zagrożeń. Kontenery dzielą jądro (kernel) z systemem hosta, co oznacza, że kompromitacja bazy danych może prowadzić do ucieczki z kontenera (ang. *container breakout*).

Aby zminimalizować to ryzyko, stosuje się następujące praktyki:

- **Brak uprawnień roota:** Procesy DBMS (np. postgres lub mysqld) nigdy nie powinny działać jako użytkownik root wewnątrz kontenera. Standardowe obrazy często wymagają jawnego zdefiniowania dyrektywy USER w pliku Dockerfile.
- **Ograniczenia zasobów (Cgroups):** Podatność silnika bazy na ataki typu *Denial of Service* można złagodzić na poziomie infrastruktury, nakładając twarde limity na zużycie CPU i pamięci RAM przez dany kontener. Zapobiega to sytuacji, w której przeciążona baza kładzie cały serwer hosta (Resource Exhaustion).
- **Read-Only Root Filesystem:** Kontener bazy danych powinien mieć zamontowany system plików w trybie tylko do odczytu, z wyjątkiem ściśle zdefiniowanych wolumenów (ang. *volumes*) przeznaczonych na pliki danych (np. `/var/lib/postgresql/data`). Uniemożliwia to atakującemu wstrzyknięcie złośliwych skryptów do katalogów systemowych po udanym wykorzystaniu luki aplikacyjnej.

## 2. Ataki na bazy danych i luki w zabezpieczeniach

Ponieważ bazy danych przechowują najbardziej krytyczne informacje organizacji, stanowią główny cel cyberataków. Według zestawień takich jak OWASP Top 10, podatności związane ze wstrzykiwaniem kodu (Injection) oraz błędną konfiguracją od lat utrzymują się w czołówce zagrożeń. Zrozumienie mechaniki tych ataków jest kluczowe do zaprojektowania skutecznych mechanizmów obronnych w warstwie aplikacyjnej i bazodanowej.

### Wstrzykiwanie kodu SQL (SQL Injection)

SQL Injection (SQLi) to podatność polegająca na możliwości modyfikacji zapytania SQL poprzez nieodpowiednio zwalidowane dane wejściowe. Pozwala to atakującemu na wykonanie nieautoryzowanych operacji na bazie danych. Klasyczny przykład podatności (język PHP):

```
$username = $_POST['username'];
$query = "SELECT * FROM users WHERE username = '$username'";
$db->execute($query);
```

Jeśli atakujący jako parametr username przekaże ciąg `' OR '1'='1'`, zapytanie przyjmie postać:

```
SELECT * FROM users WHERE username = '' OR '1'='1';
```

Ponieważ warunek `'1'='1'` jest zawsze prawdziwy, silnik bazy danych zwróci wszystkie rekordy z tabeli `users`, omijając mechanizm uwierzytelniania.

#### Rodzaje ataków SQLi:

1. **In-Band SQLi (Classic):** Atakujący używa tego samego kanału komunikacyjnego do przeprowadzenia ataku i zebrania wyników. Najpopularniejsze to *Error-based SQLi* (wymuszanie błędów silnika w celu wycieku metadanych, np. struktury tabel) oraz *Union-based SQLi* (użycie operatora UNION do dołączenia złośliwych zapytań do oryginalnego).
2. **Inferential (Blind) SQLi:** Występuje, gdy aplikacja nie zwraca komunikatów o błędach ani bezpośrednich wyników zapytań. Atakujący musi wnioskować o strukturze danych na podstawie zachowania aplikacji.
  - \* **Boolean-based:** Wysyłanie zapytań warunkowych i obserwowanie, czy strona ładuje się inaczej.
  - \* **Time-based:** Zmuszanie bazy do wstrzymania działania (np. funkcjami `pg_sleep()` w PostgreSQL lub `WAITFOR DELAY` w SQL Server), aby potwierdzić obecność podatności.
3. **Out-of-Band SQLi:** Wykorzystywane rzadziej, opiera się na wymuszeniu przez silnik bazy danych żądania HTTP lub DNS do zewnętrznego serwera kontrolowanego przez atakującego.

**Mitygacja:** Podstawową i najskuteczniejszą metodą obrony przed SQLi jest korzystanie z **zapytań parametryzowanych (Prepared Statements)** lub nowoczesnych systemów ORM (Object-Relational Mapping), które oddzielają składnię zapytań od danych wejściowych.

### Ataki NoSQL Injection

Wraz ze wzrostem popularności nierelacyjnych baz danych (np. MongoDB, CouchDB), pojawił się mit o ich całkowitej odporności na wstrzykiwanie kodu. Choć nie używają one tradycyjnego dialektu SQL, aplikacje z nich korzystające nadal mogą być podatne na modyfikację logiki zapytań.

Ataki te często bazują na wstrzykiwaniu operatorów bazy danych do zapytań, które aplikacja interpretuje jako obiekty JSON.

**Przykład dla MongoDB:** Aplikacja Node.js oczekuje poświadczeń przekazanych w formacie JSON:

```
db.collection('users').find({
  username: req.body.username,
  password: req.body.password
});
```

Atakujący wysłał zmodyfikowany payload z użyciem operatora logicznego `$ne` (Not Equal):

```
{
  "username": {"$ne": null},
  "password": {"$ne": null}
}
```

W rezultacie silnik MongoDB wykonuje zapytanie szukające użytkownika, którego login i hasło *nie są nulle*. Zapytanie zwraca pierwszy pasujący rekord (często administratora), umożliwiając logowanie bez znajomości hasła.

## Przepełnienie bufora (Buffer Overflow) w DBMS

Silniki baz danych (np. MySQL, PostgreSQL, Oracle) to skomplikowane aplikacje napisane najczęściej w językach C lub C++, co oznacza, że są potencjalnie narażone na błędy zarządzania pamięcią.

*Buffer Overflow* w kontekście baz danych występuje, gdy atakujący przesyła nieproporcjonalnie duży ciąg danych do bufora o stałej wielkości (np. w parametrze funkcji wbudowanej, mechanizmie autoryzacyjnym lub procedurze składowanej). Gdy dane wykraczają poza zaalokowany obszar pamięci, mogą nadpisać sąsiadujące obszary, w tym wskaźnik powrotu instrukcji (Instruction Pointer).

Może to prowadzić do: 1. **Awarji silnika bazy danych (Crash)** – przerywając ciągłość działania. 2. **Wykonania dowolnego kodu (RCE - Remote Code Execution)** – uruchomienia shellcode'u na serwerze z uprawnieniami procesu bazy danych, co stanowi bezpośrednie wejście do kompromitacji hosta (powiązane z ryzykiem opisanym w rozdziale o konteneryzacji).

## Odmowa Usługi (DoS) na poziomie bazy danych

Ataki Denial of Service na bazy danych różnią się od klasycznych ataków sieciowych. Mają one charakter aplikacyjny i celują w wyczerpanie zasobów sprzętowych serwera (CPU, RAM, I/O) lub limitów samego oprogramowania.

- **Wyczerpanie puli połączeń (Connection Exhaustion):** Każdy DBMS ma zdefiniowany limit maksymalnej liczby jednoczesnych połączeń (np. parametr `max_connections` w PostgreSQL). Atakujący, często wykorzystując luki w warstwie aplikacji, może zainicjować tysiące zawieszonych lub bardzo powolnych sesji bazy, uniemożliwiając logowanie legalnym użytkownikom.
- **Asymetryczne obciążenie (Query-based DoS):** Atakujący wstrzykuje i uruchamia zapytania, które są syntaktycznie poprawne, ale drastycznie nieoptymalne kosztowo. Przykładem może być wymuszenie iloczynu kartezjańskiego (CROSS JOIN) na bardzo dużych tabelach bez odpowiednich indeksów, co może zablokować procesor serwera na kilka minut i doprowadzić do blokady całej aplikacji (Deadlock/Timeouts).

## Automatyzacja ataków: Narzędzia audytowe

W procesach testów penetracyjnych baz danych, analitycy bezpieczeństwa korzystają ze zautomatyzowanych frameworków. Najpopularniejszym z nich jest **sqlmap** – potężne narzędzie open-source automatyzujące proces wykrywania podatności Sqli i przejmowania kontroli nad serwerami bazodanowymi.

W typowym scenariuszu audytu, uruchomienie polecenia:

```
sqlmap -u "http://podatna-aplikacja.local/item.php?id=1" --dbs
```

pozwoli narzędziu na wykrycie typu wstrzyknięcia (np. czasowe lub błędowe), zidentyfikowanie używanego silnika DBMS oraz – w razie sukcesu – wyliczenie wszystkich baz danych dostępnych na serwerze (enumeracja instancji).

### 3. Zarządzanie tożsamością, uwierzytelnianie i autoryzacja

Po zabezpieczeniu infrastruktury sieciowej oraz aplikacji przed atakami typu Injection, kolejną linią obrony jest ścisła kontrola dostępu do samych danych. W architekturze systemów bazodanowych proces ten opiera się na trzech filarach: zarządzaniu tożsamością (Identity Management), uwierzytelnianiu (Authentication) oraz autoryzacji (Authorization). Prawidłowa implementacja tych mechanizmów gwarantuje, że zasada najmniejszego uprzywilejowania (PoLP - Principle of Least Privilege) może być skutecznie egzekwowana w całym systemie.

#### Uwierzytelnianie w bazach danych

Proces uwierzytelniania weryfikuje, czy podmiot (użytkownik końcowy, administrator lub usługa aplikacyjna) łączący się z bazą danych jest tym, za kogo się podaje. Współczesne silniki relacyjne (np. PostgreSQL, Oracle) oraz nierelacyjne odeszły od prostego przesyłania haseł tekstem jawnym (plaintext), wprowadzając bardziej zaawansowane mechanizmy:

- **Kryptograficzne protokoły uwierzytelniania:** Zamiast przestarzałych algorytmów (np. MD5), nowoczesne wdrożenia wykorzystują mechanizmy typu SCRAM-SHA-256 (Salted Challenge Response Authentication Mechanism). SCRAM zapobiega atakom typu *replay attack* oraz minimalizuje skutki ewentualnej kradzieży skrótów z serwera, ponieważ hasło nigdy nie jest przesyłane w otwartej formie.
- **Integracja z dostawcami tożsamości (IdP):** W środowiskach korporacyjnych unika się tworzenia lokalnych kont wewnątrz bazy (tzw. *database-native accounts*) dla użytkowników fizycznych. Zamiast tego silniki DBMS integruje się z centralnymi usługami katalogowymi (LDAP, Active Directory) lub wykorzystuje protokół Kerberos (np. poprzez GSSAPI). Pozwala to na centralne zarządzanie cyklem życia konta i automatyczne odbieranie dostępu w przypadku odejścia pracownika (tzw. *offboarding*).
- **Uwierzytelnianie certyfikatywne (mTLS - Mutual TLS):** Standard powszechnie stosowany w architekturze mikroserwisowej do komunikacji *machine-to-machine*. Oprócz szyfrowania samego kanału (TLS), serwer bazy danych żąda i weryfikuje certyfikat klienta (X.509) wystawiony przez wewnętrzne, zaufane centrum certyfikacji (CA).

#### Autoryzacja i modele kontroli dostępu

Po udanym uwierzytelnieniu następuje faza autoryzacji, czyli weryfikacji, jakie operacje (SELECT, INSERT, UPDATE, DELETE) i na jakich obiektach (tabele, widoki, procedury) dany podmiot może wykonać.

##### Kontrola dostępu oparta na rolach (RBAC - Role-Based Access Control)

Model RBAC to absolutny standard w systemach zarządzania bazami danych. Zamiast nadawać uprawnienia (GRANT) bezpośrednio pojedynczym użytkownikom, tworzy się logiczne role odzwierciedlające funkcje biznesowe lub techniczne (np. `app_readonly`, `app_writer`, `dba_admin`). Następnie konta personalne lub serwisowe przypisuje się do tych ról. Taka abstrakcja drastycznie upraszcza audyt i zarządzanie uprawnieniami.

Przykład implementacji RBAC (dialekt PostgreSQL):

```
-- Utworzenie technicznej roli tylko do odczytu
CREATE ROLE app_readonly;
GRANT CONNECT ON DATABASE production TO app_readonly;
GRANT USAGE ON SCHEMA public TO app_readonly;
GRANT SELECT ON ALL TABLES IN SCHEMA public TO app_readonly;

-- Przypisanie użytkownika raportującego do przygotowanej roli
GRANT app_readonly TO report_user;
```

#### Bezpieczeństwo na poziomie wierszy (Row-Level Security)

Tradycyjny model autoryzacji w bazach danych działa na poziomie całych struktur (np. blokuje lub zezwala na odczyt całej tabeli). Współczesne aplikacje, zwłaszcza budowane w modelu wielodostępnym (multi-tenant), często wymagają znacznie bardziej granularnej kontroli, aby użytkownik jednego klienta nie miał fizycznej możliwości odczytania rekordów należących do innego.

Z pomocą przychodzi mechanizm Row-Level Security (RLS). Pozwala on na nakładanie polityk bezpieczeństwa bezpośrednio na wiersze danych. Silnik bazy automatycznie i w sposób przezroczysty dokleja zdefiniowane warunki do każdego zapytania. Kluczową zaletą RLS jest fakt, że uniemożliwia on ominięcie logiki izolacyjnej w warstwie aplikacji – nawet w przypadku wystąpienia luki SQL Injection.

Przykład definicji RLS (dialekt PostgreSQL):

```
-- Włączenie weryfikacji RLS dla krytycznej tabeli
ALTER TABLE orders ENABLE ROW LEVEL SECURITY;

-- Utworzenie polityki izolującej dane między użytkownikami
CREATE POLICY isolate_tenant_policy ON orders
    USING (tenant_id = current_setting('app.current_tenant')::int);
```

## Zarządzanie poświadczeniami aplikacji (Secrets Management)

Nawet najbardziej rygorystyczne mechanizmy wewnątrz samej bazy danych zawiodą, jeśli poświadczenia do niej (tzw. *connection strings*) zostaną umieszczone na stałe (hardcoded) w kodzie źródłowym i wypchnięte do repozytorium kodu.

Zgodnie z dobrymi praktykami nurtu DevSecOps, środowiska produkcyjne powinny wykorzystywać zewnętrzne systemy zarządzania sekretami (np. HashiCorp Vault, AWS Secrets Manager). Narzędzia te pozwalają na dynamiczne generowanie tymczasowych, krótkożyjących poświadczeń (tzw. *dynamic secrets*). W takim scenariuszu aplikacja uwierzytelnia się do Vaulta i otrzymuje login oraz hasło do bazy danych, które wygasają np. po godzinie. Po tym czasie usługa zarządzająca automatycznie usuwa (REVOKE) te poświadczenia z silnika bazy, co radykalnie zmniejsza okno potencjalnego ataku w przypadku ich wycieku.

## 4. Kryptografia w bazach danych

Nawet najbardziej rygorystyczne mechanizmy kontroli dostępu i izolacji sieciowej mogą zawieść w obliczu zaawansowanych ataków (tzw. APT – Advanced Persistent Threats) lub błędów ludzkich. W myśl zasady obrony w głąb (Defense in Depth), ostatnią linią ochrony informacji jest kryptografia. Jej implementacja w środowiskach bazodanowych dzieli się na trzy główne obszary: ochronę danych w spoczynku, w tranzycie oraz w użyciu.

### Szyfrowanie danych w spoczynku (Data at Rest)

Szyfrowanie w spoczynku ma na celu zabezpieczenie fizycznych nośników danych przed nieautoryzowanym odczytem, na przykład w przypadku kradzieży serwera, dysku twardego lub nieautoryzowanego skopiowania plików kopii zapasowych.

Przemysłowym standardem w tym zakresie jest mechanizm **TDE (Transparent Data Encryption)**, natywnie wspierany przez silniki takie jak Microsoft SQL Server czy Oracle (dla PostgreSQL stosuje się często szyfrowanie na poziomie systemu plików, np. LUKS, lub dedykowane rozszerzenia). TDE działa na poziomie warstwy wejścia/wyjścia (I/O) silnika bazy danych:

- **Przezroczystość:** Aplikacja kliencka nie musi być modyfikowana. Dane są szyfrowane tuż przed zapisem na dysk i deszyfrowane w momencie wczytywania ich do pamięci operacyjnej (RAM) serwera.
- **Architektura kluczy:** Bezpieczeństwo TDE opiera się na hierarchii kluczy kryptograficznych. Dane właściwie szyfrowane są kluczem symetrycznym DEK (Data Encryption Key). Sam DEK jest z kolei chroniony (szyfrowany) asymetrycznym kluczem nadrzędnym MEK (Master Encryption Key), który powinien być przechowywany poza samym serwerem bazy danych – najczęściej w sprzętowych modułach bezpieczeństwa (HSM) lub chmurowych usługach KMS (Key Management Service).

### Szyfrowanie danych w tranzycie (Data in Transit)

Przesyłanie danych między warstwą aplikacji a silnikiem bazy danych w postaci jawnej (plaintext) naraża system na ataki typu Man-in-the-Middle (MitM) oraz podsłuchiwanie pakietów (sniffing).

Aby temu zapobiec, wszystkie połączenia z bazą danych muszą być obligatoryjnie szyfrowane za pomocą protokołu **TLS (Transport Layer Security)**. Wymuszenie bezpiecznego kanału realizuje się zazwyczaj poprzez odpowiednią konfigurację parametrów połączenia.

Przykład wymuszenia TLS w konfiguracji PostgreSQL (`postgresql.conf`):

```
# Włączenie obsługi protokołu TLS
ssl = on
ssl_cert_file = '/etc/ssl/certs/db-server.crt'
ssl_key_file = '/etc/ssl/private/db-server.key'
# Odrzucanie połączeń używających przestarzałych, podatnych wersji protokołu
ssl_min_protocol_version = 'TLSv1.2'
```

Po stronie klienta, ciąg połączeniowy (connection string) powinien zawierać dyrektywę bezwzględnie wymagającą weryfikacji certyfikatu (np. parametr `sslmode=verify-full`).

## Szyfrowanie na poziomie klienta (Client-Side Encryption)

Mechanizm TDE chroni przed fizyczną kradzieżą nośników, ale nie zabezpiecza przed administratorem bazy danych (DBA) lub atakiem SQL Injection, ponieważ w momencie działania zapytania dane w pamięci serwera są w pełni odszyfrowane.

Odpowiedzią na ten problem jest szyfrowanie na poziomie aplikacji (lub kolumn w nowszych silnikach, np. funkcja *Always Encrypted* w SQL Server). W tym paradygmacie dane są szyfrowane w warstwie aplikacji (np. backendzie w Javie lub C#) jeszcze przed wysłaniem ich do bazy.

Silnik bazy danych operuje wyłącznie na kryptogramach (ciphertext) i nigdy nie ma dostępu do kluczy deszyfrujących, co zapewnia najwyższy poziom poufności dla najbardziej wrażliwych kolumn (np. numerów PESEL, danych kart kredytowych). Kosztem takiego rozwiązania jest utrata możliwości wykonywania zaawansowanych operacji analitycznych (takich jak sumowanie, sortowanie czy wyszukiwanie z użyciem operatora LIKE) bezpośrednio po stronie DBMS.

## Dynamiczne maskowanie danych i funkcje skrótu

Uzupełnieniem kryptografii jest technika **DDM (Dynamic Data Masking)**. Służy ona do ochrony wrażliwych danych w czasie rzeczywistym przed użytkownikami, którzy nie posiadają odpowiednich poświadczeń (np. analitykami biznesowymi lub programistami korzystającymi z kopii produkcyjnej). DDM maskuje wyniki zapytań (np. zwracając ciąg `****_****_****-1234` zamiast pełnego numeru karty), podczas gdy same dane na dysku pozostają nienaruszone.

Ponadto, wracając do zagadnień z zakresu uwierzytelniania, należy pamiętać o kryptografii jednokierunkowej. Wrażliwe poświadczenia (takie jak hasła użytkowników aplikacji) nigdy nie mogą być przechowywane w formie szyfrowalnej (dwukierunkowej). Zamiast tego muszą być poddawane procesowi solenia (salting) i hashowania z wykorzystaniem funkcji spowalniających (Key Derivation Functions), takich jak **Argon2**, **bcrypt** lub **PBKDF2**, co skutecznie uniemożliwia ataki słownikowe i wykorzystanie tęczyowych tablic (rainbow tables).

## 5. Audyt, logowanie i wykrywanie anomalii

Nawet najsilniejsze mechanizmy prewencyjne, takie jak kontrola dostępu czy szyfrowanie, nie gwarantują stuprocentowego bezpieczeństwa. W przypadku udanego ataku lub błędu wewnętrznego (tzw. zagrożenia *Insider Threat*), kluczowe staje się odtworzenie przebiegu zdarzeń. Temu celowi służą mechanizmy audytu i logowania, które stanowią fundament dla systemów wykrywania anomalii oraz zapewniają niezaprzeczalność (ang. *Non-repudiation*) operacji wykonywanych na danych.

## Znaczenie audytu i rodzaje logów bazodanowych

Audytowanie bazy danych to proces polegający na monitorowaniu i rejestrowaniu akcji użytkowników oraz procesów systemowych. Nie należy mylić go z klasycznymi logami transakcyjnymi (np. WAL w PostgreSQL czy Redo Logs w Oracle), które służą do odtwarzania bazy po awarii. Audyt bezpieczeństwa skupia się na tym **kto**, **kiedy**, **skąd** i **jaka** operację wykonał.

Większość nowoczesnych silników DBMS pozwala na granularną konfigurację logowania. Rejestrowane zdarzenia można podzielić na kilka kategorii: \* **Logi uwierzytelniania**: Rejestrują udane i nieudane próby logowania (np. błędy *Access Denied*), co pozwala na szybkie wykrycie ataków typu brute-force. \* **Logi DDL (Data Definition Language)**: Śledzą zmiany w strukturze bazy (tworzenie i usuwanie tabel, modyfikacje uprawnień). \* **Logi DML (Data Manipulation Language)**: Najbardziej kosztowne wydajnościowo, ale niezbędne w systemach o wysokim rygorze bezpieczeństwa (np. bankowość, opieka zdrowotna). Pozwalają na śledzenie zapytań SELECT, UPDATE czy DELETE na wrażliwych tabelach.

Przykładowo, natywne logowanie w PostgreSQL jest często niewystarczające dla zaawansowanego audytu. W środowiskach produkcyjnych powszechnie stosuje się rozszerzenie **pgAudit** (PostgreSQL Audit Extension), które dostarcza szczegółowe logowanie sesji i obiektów przy użyciu standardowych mechanizmów logowania wbudowanych w silnik.

## Centralizacja logów i systemy SIEM

Przechowywanie logów audytowych wyłącznie na tym samym serwerze, na którym działa baza danych, jest poważnym błędem architektonicznym. W przypadku udanej kompromitacji hosta (np. poprzez ucieczkę z kontenera opisaną w rozdziale 1), atakujący w pierwszej kolejności zacierza ślady, modyfikując lub usuwając pliki logów.

Dlatego standardem rynkowym jest natychmiastowy eksport logów w czasie rzeczywistym do niezależnych systemów centralnych. Wykorzystuje się do tego architekturę SIEM (ang. *Security Information and Event Management*), z wykorzystaniem stosów technologicznych takich jak **ELK** (Elasticsearch, Logstash, Kibana) lub **Splunk**. Systemy te agregują logi nie tylko z baz danych, ale również z warstwy aplikacji, firewalli i systemów operacyjnych, pozwalając na korelację zdarzeń z różnych źródeł w celu identyfikacji złożonych ataków.

## Database Activity Monitoring (DAM) i wykrywanie anomalii

Tradycyjna analiza logów jest procesem reaktywnym (po fakcie). Aby przejść na model proaktywny, stosuje się systemy DAM (ang. *Database Activity Monitoring*), które monitorują ruch do bazy danych z zewnątrz (np. analizując ruch sieciowy (tzw. *packet sniffing*) lub podpinając się pod pule pamięci silnika). Dzięki temu system DAM jest odseparowany od samej bazy, co zapobiega modyfikacji jego działania nawet po przejściu uprawnień administratora bazy (DBA).

Kluczową funkcją nowoczesnych systemów z tej kategorii jest **wykrywanie anomalii w oparciu o analizę behawioralną (UEBA)**. Zamiast opierać się wyłącznie na statycznych sygnaturach zagrożeń, systemy te wykorzystują algorytmy uczenia maszynowego do modelowania „normalnego” zachowania aplikacji i użytkowników.

System wykryje anomalię i podniesie alarm (lub zablokuje zapytanie), gdy np.: \* Aplikacja webowa, która zazwyczaj pobiera pojedyncze rekordy w zapytaniach SELECT, nagle próbuje wykonać zrzut (ang. *dump*) tysięcy wierszy z tabeli klientów – co może świadczyć o udanym wstrzyknięciu kodu (SQLi z rozdziału 2) i próbie ekstrakcji danych. \* Użytkownik o uprawnieniach administracyjnych loguje się do bazy z nietypowej geolokalizacji lub poza standardowymi godzinami pracy. \* Gwałtownie rośnie liczba odrzucanych połączeń lub błędów składniowych SQL z określonego adresu IP wewnątrz sieci.

## 6. Bezpieczeństwo kopii zapasowych i Disaster Recovery

Systemy prewencyjne i detekcyjne nie zawsze są w stanie zatrzymać zaawansowane ataki, takie jak ransomware, czy też zapobiec fizycznym awariom infrastruktury. W takich scenariuszach ostateczną linią obrony stają się mechanizmy odtwarzania danych po awarii. Bezpieczeństwo samych kopii zapasowych jest równie krytyczne co bezpieczeństwo głównej instancji bazy danych – skompromitowany backup często ostatecznie przekreśla szanse na powrót organizacji do normalnego funkcjonowania operacyjnego.

### Zasada 3-2-1 i niezmienność kopii (Immutable Backups)

Klasyczna reguła 3-2-1 (trzy kopie, na dwóch różnych nośnikach, z czego jedna w innej lokalizacji fizycznej lub geograficznej) pozostaje fundamentem ochrony danych. Jednakże, w dobie zaawansowanych ataków kryptograficznych, wymaga ona uzupełnienia o koncepcję niezmienności (ang. *Immutability*).

Współczesne złośliwe oprogramowanie często priorytetyzuje poszukiwanie dysków sieciowych oraz zasobów chmurowych z kopiami zapasowymi, aby je usunąć lub zaszyfrować przed zaatakowaniem głównego klastra bazy danych. Odpowiedzią inżynierską na to zagrożenie jest technologia zapisu WORM (ang. *Write Once, Read Many*). W nowoczesnej architekturze chmurowej (np. za pomocą mechanizmu AWS S3 Object Lock) gwarantuje ona, że zapisany plik backupu nie może zostać w żaden sposób zmodyfikowany ani usunięty przez zdefiniowany okres retencji. Ochrona ta działa nawet w przypadku całkowitej kompromitacji konta z najwyższymi uprawnieniami (ang. *root account compromise*).

## Szyfrowanie archiwów i zarządzanie kluczami

Ponieważ logiczne i fizyczne kopie zapasowe opuszczają bezpieczne środowisko serwerowni lub głęboko izolowanej podsieci (VPC, o której mowa w rozdziale 1), absolutnym wymogiem jest ich szyfrowanie w spoczynku (ang. *Data at Rest Encryption*). Wykonanie zwykłego zrzutu bazy w postaci czystego tekstu i przesłanie go na zewnątrz to drastyczne ryzyko wycieku, uderzające bezpośrednio w postulat poufności.

W nowoczesnych wdrożeniach archiwizacji stosuje się dedykowane systemy KMS (ang. *Key Management Service*). Klucze szyfrujące używane do ochrony backupów powinny być ściśle odseparowane od infrastruktury samego klastra bazodanowego. Dodatkowo podczas procesu odtwarzania konieczna jest weryfikacja integralności archiwów przy użyciu funkcji skrótu (np. SHA-256), co pozwala upewnić się, że paczka danych nie uległa uszkodzeniu na etapie przesyłania.

## Disaster Recovery (DR) i wskaźniki RTO/RPO

Kopia zapasowa to jedynie nośnik danych; z perspektywy ciągłości biznesowej (ang. *Business Continuity*) liczy się sprawdzony proces ich przywracania. Architektura Disaster Recovery dla baz danych opiera się na dwóch krytycznych metrykach:

- **RPO (Recovery Point Objective):** Maksymalny akceptowalny czas, z którego dane mogą zostać bezpowrotnie utracone. Minimalizację tego wskaźnika do okolic zera osiąga się poprzez ciągłą strumieniową archiwizację logów transakcyjnych (np. mechanizm *WAL archiving* w PostgreSQL).
- **RTO (Recovery Time Objective):** Czas niezbędny na przywrócenie systemów bazodanowych do pełnego działania operacyjnego po awarii.

Dla systemów o rygorystycznym RTO (wymagających dostępności mierzonej w sekundach) tradycyjne odtwarzanie z plików jest niewystarczające. Stosuje się wówczas architekturę klastrów rozproszonych w modelach *Active-Passive* (ciągła, asynchroniczna replikacja do zapasowego centrum danych) lub *Active-Active* (synchroniczny zapis w wielu lokalizacjach, wymagający specjalnego rozwiązywania problemów ze spójnością i opóźnieniami sieciowymi, tzw. *split-brain*).

Niezależnie od stopnia skomplikowania architektury chmurowej, każda polityka Disaster Recovery pozostaje martwym dokumentem, dopóki nie zostanie poddana rygorystycznym, regularnym i udokumentowanym testom odtworzeniowym (*Disaster Recovery Drills*) w odizolowanym środowisku.

### 2.2.8 Kopie zapasowe

## 2.3 Zadanie 3

## 2.4 Implementacja bazy danych i import danych

W ramach czwartego rozdziału zrealizowano dwa kluczowe etapy prac wdrożeniowych: utworzenie struktur tabelarycznych zdefiniowanych w modelu fizycznym oraz wdrożenie zoptymalizowanych mechanizmów importu danych testowych. Prace przeprowadzono w sposób równoległy dla środowiska lokalnego opartego na silniku SQLite oraz serwerowego wykorzystującego system PostgreSQL.

### 2.4.1 Definicja i inicjalizacja struktur danych

Pierwszym etapem wdrażania systemu bazodanowego było przeniesienie założeń modelu fizycznego do wytypowanych systemów zarządzania bazami danych (DBMS). Proces ten wymagał adaptacji skryptów DDL (Data Definition Language) do specyficznych dialektów SQL obsługiwanych przez wybrane środowiska.

W przypadku **PostgreSQL**, definicje tabel utworzono wykorzystując zaawansowane typy danych (np. NUMERIC) oraz współczesne metody autoinkrementacji kluczy głównych poprzez klauzulę **GENERATED ALWAYS AS IDENTITY**. Poniżej przedstawiono implementację dla kluczowych tabel, ilustrującą nałożone więzy integralności (unikalność i kontrolę dat):

```
-- Fragment definicji kluczowych tabel (PostgreSQL)
CREATE TABLE Klienci (
    ID_Klienta INT GENERATED ALWAYS AS IDENTITY PRIMARY KEY,
    Imie VARCHAR(50) NOT NULL,
    Nazwisko VARCHAR(100) NOT NULL,
    PESEL VARCHAR(11) UNIQUE NOT NULL,
    Nr_Prawa_Jazdy VARCHAR(20) UNIQUE
);

CREATE TABLE Wypozyczenia (
    ID_Wypozyczenia INT GENERATED ALWAYS AS IDENTITY PRIMARY KEY,
    ID_Klienta INT NOT NULL,
    Data_Od DATE NOT NULL,
    Data_Do DATE NOT NULL,
    CONSTRAINT fk_klient FOREIGN KEY (ID_Klienta) REFERENCES Klienci(ID_Klienta),
    CONSTRAINT sprawdz_daty CHECK (Data_Do >= Data_Od)
);
```

W środowisku **SQLite**, będącym lekką bazą wbudowaną, wykorzystano uproszczone mapowanie typów (INTEGER, TEXT). Proces inicjalizacji wymagał wywołania procedury aktywującej wsparcie dla więzów referencyjnych za pomocą dyrektywy **PRAGMA foreign\_keys = ON;**, co zostało zaprezentowane na poniższym fragmencie kodu implementującego tabele z kluczem obcym:

```
-- Fragment definicji kluczowych tabel (SQLite)
PRAGMA foreign_keys = ON;

CREATE TABLE Klienci (
    ID_Klienta INTEGER PRIMARY KEY,
    Imie TEXT NOT NULL,
    Nazwisko TEXT NOT NULL,
    PESEL TEXT UNIQUE NOT NULL
);

CREATE TABLE Wypozyczenia (
    ID_Wypozyczenia INTEGER PRIMARY KEY,
    ID_Klienta INTEGER,
    Data_Od TEXT NOT NULL,
    Data_Do TEXT NOT NULL,
    FOREIGN KEY (ID_Klienta) REFERENCES Klienci(ID_Klienta)
);
```

### 2.4.2 Zasilenie bazy danymi demonstracyjnymi

Na etapie testowania architektury modelu fizycznego, puste relacje zostały zasilone małym zbiorem danych demonstracyjnych wykorzystując klasyczne polecenia DML z rodziny INSERT. Procedura ta miała na celu weryfikację poprawności działania nałożonych ograniczeń integralnościowych – na przykład weryfikację unikalności numerów PESEL i numerów rejestracyjnych pojazdów oraz zgodność typów asocjacyjnych.

### 2.4.3 Koncepcja mechanizmów masowego importu (ETL)

Dla zasymulowania warunków produkcyjnych i obciążenia systemów większym wolumenem rekordów, utworzono standaryzowany plik formatu CSV reprezentujący logikę płaskich rekordów z informacjami o potencjalnych klientach.

Zarówno dla SQLite, jak i PostgreSQL, pierwszym krokiem w środowisku języka Python było odczytanie płaskiego pliku i przeniesienie go do ustrukturyzowanej, iterowalnej pamięci RAM (np. w postaci listy list):

```
import csv

# Wczytywanie danych z pliku CSV do struktury iterowalnej
with open('klienci.csv', 'r', encoding='utf-8') as plik_csv:
    reader = csv.reader(plik_csv)
    next(reader) # Pomińcie wiersza z nagłówkami
    dane_z_csv = [row for row in reader]
```

Mając przygotowaną strukturę w pamięci aplikacji, przystąpiono do operacji ładowania danych, przyjmując strategię adekwatną do natury silników bazodanowych.

### Mechanizm COPY w PostgreSQL

Ze względu na architekturę klient-serwer, przesyłanie tysięcy pojedynczych zapytań INSERT wiąże się z ogromnym kosztem operacyjnym ze względu na opóźnienia sieciowe oraz narzut parsowania po stronie serwera. Wdrożono zatem natywną dla PostgreSQL instrukcję COPY obsługującą strumieniowanie wejścia (STDIN):

```
# Właściwy proces wsadowego importu do bazy PostgreSQL
# (Zakładając aktywne połączenie psycopg2/psycopg3 pod zmienną conn_pg)

with conn_pg.cursor() as cursor_pg:
    # Zastosowanie strumieniowania binarnego wprost do pamięci buforowej Postgresa
    with cursor_pg.copy(
        "COPY Klienci (Imie, Nazwisko, PESEL, Nr_Prawa_Jazdy, Telefon, Email) FROM_
↪STDIN"
    ) as copy_operation:
        for row in dane_z_csv:
            copy_operation.write_row(row)

conn_pg.commit()
```

Takie podejście buduje ciągły potok danych bezpośrednio do pliku tabeli, omijając standardową kontrolę transakcyjną planisty (query planner) dla każdego pojedynczego wiersza z osobna, co jest referencyjnym wzorcem w środowiskach inżynierii danych.

### Mechanizm Batch Insert w SQLite

W silniku SQLite wykorzystano z kolei grupowanie instrukcji poprzez metodę executemany() dostępną w sterowniku języka Python. Ponieważ cała baza jest jednoplikowa, wykonanie całego wsadu w obrębie jednej otwartej i zatwierdzonej tylko raz na końcu transakcji redukuje obciążenie I/O systemu plików do minimum.

## 2.5 Zadanie 5